IEEE Access
Multidisciplinary ⋮ Rapid Review ⋮ Open Access Journal

Received 24 June 2024, accepted 15 August 2024, date of publication 26 August 2024, date of current version 24 September 2024.

Digital Object Identifier 10.1109/ACCESS.2024.3450306

SURVEY

Migrating Software Systems Toward Post-Quantum Cryptography–A Systematic Literature Review

CHRISTIAN NÄTHER[1], DANIEL HERZINGER[2], STEFAN-LUKAS GAZDAG[2], JAN-PHILIPP STEGHÖFER[1], (Member, IEEE), SIMON DAUM[2], AND DANIEL LOEBENBERGER[3]

[1]XITASO GmbH, 86153 Augsburg, Germany
[2]genua GmbH, 85551 Kirchheim, Germany
[3]Fraunhofer AISEC, 85748 Garching, Germany

Corresponding author: Christian Näther (christian.naether@xitaso.com)

This work was supported by German Federal Ministry of Education and Research.

ABSTRACT Networks such as the Internet are essential for our connected world. Quantum computing threatens its fundamental security mechanisms. Therefore, a migration to post-quantum-cryptography (PQC) is necessary for networks and their components. Currently, there is little knowledge on how such migrations should be structured and implemented in practice. Our systematic literature review addresses migration approaches for IP networks towards PQC. It surveys papers about the migration process and exemplary real-world software system migrations. On the process side, we found that terminology, migration steps, and roles are not defined precisely or consistently across the literature. Still, we identified four major phases and appropriate substeps which we matched with also emerging archetypes of roles. In terms of real-world migrations, we see that reports used several different PQC implementations and hybrid solutions for migrations of systems belonging to a wide range of system types. Across all papers we noticed three major challenges for adopters: missing experience of PQC and a high realization effort, concerns about the security of the upcoming system, and finally, high complexity. Our findings indicate that recent standardization efforts already push quantum-safe networking forward. However, the literature is still not in consensus about definitions and best practices. Implementations are mostly experimental and not necessarily practical, leading to an overall chaotic situation. To better grasp this fast moving field of (applied) research, our systematic literature review provides a comprehensive overview of its current state and serves as a starting point for delving into the matter of PQC migration.

INDEX TERMS Migration, post-quantum cryptography, quantum-safe, transition.

I. INTRODUCTION

The awareness of potential future attacks based on quantum computers is being raised continuously [22]. As the disruptive technology of quantum computing may cause a cryptographic apocalypse by overthrowing or weakening secure building blocks of our digital communication, the call for quantum-safe solutions is rising as well (compare, e.g., [23], [24]). Despite the enormous efforts around the globe to provide such future-proof alternatives, the past catches up with us. Networking — meaning the Internet as well as private IP networks connected to the Internet — is based on a wide range of very old to brand new technologies. Updating this ever-growing infrastructure is a difficult task on its own and suitable frameworks usually encounter a major question which is not sufficiently addressed in research and practice: *How to migrate to quantum-safe mechanisms in such a complex ecosystem given the diverse requirements and constraints by protocols and (non-standard) implementations?*

The associate editor coordinating the review of this manuscript and approving it for publication was Shuangqing Wei.

© 2024 The Authors. This work is licensed under a Creative Commons Attribution 4.0 License.
For more information, see https://creativecommons.org/licenses/by/4.0/

Practical knowledge about this transition or migration — especially on a broader scale — is limited (e.g., [25], [26]). Public institutions, companies, and organizations are starting with the first relevant steps such as creating cryptographic inventories and undertaking risk assessment. While there are various ways to perform these tasks, especially the actual transition can only be described in either a very abstract way or by deep-diving into very specific use-cases. Over time this will likely converge, but for now no comprehensive account of a practical transition can be given. Not only people new to the topic are overwhelmed by the sheer number of academic papers, reports, handbooks, and other documents available. During an initial literature assessment several hundred publications emerged. Though the work behind these is important and relevant, deducing a concrete guideline for the transition is difficult. By means of a Systematic Literature Review (SLR) we try to identify the most relevant publications available.

A. RELATED SECONDARY STUDIES

As the research related to PQC and in particular migration to PQC is still comparatively new, only a small set of secondary studies are available in that field.

A 2020 study in this area was conducted by Lohachab et al. [27]. There, the authors examined several aspects of PQC in IoT networks, including migration. The authors' broader approach means, however, that there is no in-depth look at migration and that it is entirely confined to the IoT context.

A year later, a secondary study by Wiesmaier et al. [28] provides a comprehensive survey of the literature about migration and cryptographic agility up to 2021. The fast moving topic of PQC research and the fact that the manuscript is a preprint that was not yet peer-reviewed as to our knowledge, demands a more recent look at the topic.

Partly the same team of authors as from [28] also published Alnahawi et al. [29] in 2023. That study is similar to Wiesmaier et al. [28] but focuses solely on the aspect of cryptographic agility and not PQC migration.

In a 2022 study by Giron et al. [30], the authors examine the aspects of hybrid PQC key exchanges. Those are widely seen as an important building block for network security during the migration towards PQC architectures.

Those secondary studies give insights either into topics adjacent to PQC migration or into subtopics of it. Neither of them addresses the PQC migration systematically and holistically.

Therefore, our study identifies and characterizes the state of the art regarding the migration of existing software systems towards quantum-resistance by means of a Systematic Literature Review (SLR). We identify the most relevant publications available, extract concordant information on the migration, and reduce bias by a reproducible procedure. Thus, our work benefits the PQC community and potential implementers as an overview and starting point into the current state of this field of research.

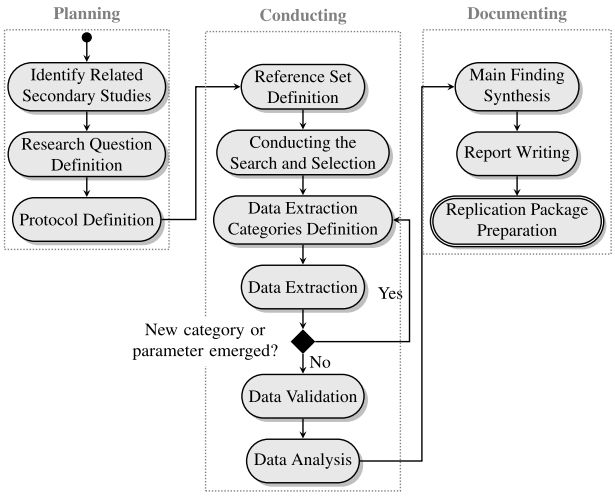


FIGURE 1. Procedure of our search and selection process.

II. RESEARCH METHODOLOGY

In the following, we describe our research methodology. Section II-A explains the general process that was used to conduct the systematic literature review and its individual steps. The first step was to identify related secondary studies, which we have already described in Section I-A. Afterwards, we outline the definition of the research questions in Section II-B and the outline of a suitable protocol to identify relevant literature in Section II-C. Section II-D describes how we compiled the reference set of relevant papers used in quality control of the search protocol. Section II-E describes the search and selection process for relevant literature. Section II-F outlines data extraction and synthesis.

A. OVERVIEW OF THE RESEARCH PROCESS

Our research process is based on the PRISMA 2020 statement [31] and Kitchenham and Brereton [32], which serves as a guideline for transparent and uniform systematic reviews. We systematically gathered and analyzed relevant literature, adhering to a three-step approach: planning, conducting, and documenting the review. This methodology has emerged as well-established in various relevant publications [32], [33], [34]. Figure 1 and the subsequent subsections illustrate how we implement the procedure using the three phases and their corresponding steps.

1) PLANNING

The planning phase provides the necessary foundation for the successful execution of the subsequent phases. To avoid duplication and to create a working basis, related secondary studies in a similar scope and context were identified, as shown in Section I-A. Since these studies lack concrete and holistic guidance for PQC migration, we defined research questions (see Section II-B) and designed a research protocol to answer these questions (see Section II-C). More specifically, the research protocol provides a comprehensive account of the steps we undertook during the different phases. The protocol

is based on Moher et al. [35], which contains the preferred reporting items for systematic literature protocols.

2) CONDUCTING

The Conducting Phase involves the identification, extraction, and analysis of relevant data. We start by defining a reference set which contains a number of manually selected papers that serve as a guideline for the subsequent steps (see Section II-D). A fixed number of databases and search engines were then used to capture the most relevant articles. These were matched against extraction criteria, explicitly designed to specify the content as well as additional criteria, such as that the sources we used had to be written in English. Once the extraction criteria have been defined (see Section II-F1), the next step is to extract the data according to our quality assurance plan. After the actual extraction, the data is then analyzed.

3) DOCUMENTING

The documenting phase is the third and final phase. The first step is to synthesize the previously analyzed data by comparing the findings and preparing a condensed shared truth. After writing the report, the final step is the preparation and provision of a replication package. The aim of this package is to make our work available to other researchers so that they can verify and reuse the data.

B. RESEARCH QUESTIONS

The three central research questions of this study are a refinement of the overarching question we posed in Section I.

RQ1: *What are the identified steps for the migration of software systems towards post-quantum cryptography?*

To ensure that a PQC migration can be carried out, a corresponding process must be available. We aim to provide a classification of the fundamental phases that need to be done for a successful post-quantum migration of a software system by answering RQ1. We also intend to refine some of the phases into concrete steps for an even more precise and practically applicable procedure. Apart from the migration phases and their steps, the roles that take on responsibility for those tasks will also be covered within RQ1. This provides practitioners with a direct role assignment for the individual phases which gives structure to the process and thereby reduces the remaining planning effort.

RQ2: *How is PQC applied when migrating software systems towards post-quantum cryptography?*

This research question aims to determine the actual adaptation of the software systems and standards for which the PQC migration was carried out. Furthermore, we want to identify the usage of hybrid solutions after the migration.

RQ3: *Which challenges emerge when migrating software systems towards post-quantum cryptography?*

Potential challenges play a decisive role for improving the planning and implementation of the migration process. RQ3 therefore aims to identify technical and organizational challenges.

These research questions comprehensively address PQC migration. The RQs cover the main building blocks and obstacles for a feasible and sensible migration, covering the topic from different perspectives.

```
(migrat* OR shift* OR retrofit* OR
integrat* OR incorporat* OR mak*) AND
((quantum* AND crypto*) OR PQC)
```

LISTING 1. Search string.

C. RESEARCH PROTOCOL DEFINITION

The research protocol consists of our selection criteria II-C1, our search strategy II-C2, and the quality assurance plan II-C3.

1) SELECTION CRITERIA

Our selection criteria are divided into inclusion and exclusion criteria and summarized in Table 1. The acceptance of an article in the final paper set required the fulfillment of all inclusion criteria as well as the non-fulfillment of all exclusion criteria.

Inclusion criteria 1 and 2 as well as exclusion criteria 1 to 5 are generic criteria, whereas all other criteria are specific to our research questions. The first inclusion criterion aims to only include papers that provide new insights and, therefore, exclude secondary studies such as surveys or similar. The second and third inclusion criteria as well as exclusion criteria 1 to 5 are self-explanatory. The term "migration mechanisms", mentioned in exclusion criteria 6 and 7, generalizes various migration-related aspects like migration methodology, procedures, frameworks, technologies, or similar. Exclusion criterion 8 focuses on migrating existing standards towards post-quantum cryptography or designing a post-quantum cryptography algorithm. Exclusion criterion 9 describes approaches for quantum key distribution or similar topics.

2) SEARCH STRATEGY

The search strategy includes the selection of resources to be searched, the definition of a search string, and the specification of a search procedure. Seven different databases, one search engine, and 25 different conference proceedings were selected as resources. These are shown in Table 2.

The search string shown in Listing 1 was used for the databases and search enginge, refined iteratively, and validated according to our quality assurance plan. The search has been further specified for each resource by using appropriate filters in combination with the search string to ensure accurate usage and therefore optimal results. Our replication package contains the corresponding search string and its filter for each resource.

TABLE 1. Selection criteria.

Inclusion Criteria
1) Primary studies or secondary studies that also provide an explicit research character.
2) Studies that are classified as academic literature or specific grey literature, including technical and research reports, work in progress, white papers, government documents, conference / workshop contributions, journal papers, PhD and master theses, as well as preprints.
3) Studies that address methodologies, frameworks, or techniques for migrating existing software resources towards post-quantum cryptography.
Exclusion Criteria
1) Duplicates of already included studies.
2) Grey literature that are blog posts, websites, RSS feed, videos, podcasts, and webinars.
3) Older version of an already included study.
4) Studies that are not available, and hence not analyzable (e.g., the full text of a scientific article is not accessible or the link to a web page is broken).
5) Studies written in any language other than English.
6) Studies that do not address migration mechanisms.
7) Studies that do not provide sufficient details about migration mechanisms.
8) Studies that do not address a software system related migration.
9) Studies that focus on quantum cryptography, i.e., Quantum Key Distribution (QKD) or Quantum Communication.

The main steps of our search procedure include the specification of an initial upper limit for each resource, the removal of duplicates, the application of the selection criteria, and the implementation of snowballing. The exact procedure is described in Section II-E.

3) QUALITY ASSURANCE PLAN

The last element of our protocol is the quality assurance plan. It has the goal to prevent potential bias by ensuring various researchers engage in the whole process and that there is a common understanding of the underlying principles. Table 3 shows the different assurances and the steps taken.

D. REFERENCE SET

The reference set serves as a guideline to identify articles that could be part of the final paper set. It is also used to formulate the inclusion and exclusion criteria which are then tested against the reference set. Accordingly, the reference set also changed until the criteria were final. The initial reference set is based on:

1) the referenced articles in related secondary studies;
2) our own pre-existing knowledge as well as knowledge from existing networks of experts in the PQC field;
3) searches in Google Scholar.

The reference set was used to validate the outcomes of the search and selection step.

TABLE 2. Resources we searched for relevant sources.

Databases
1) ACM Digital Library
2) IEEE Xplore
3) Springer Link
4) TNO Repository
5) ETSI
6) Cryptology ePrint Archive
7) Open Quantum Safe Project
Search Engines
1) Google Scholar
Conference Proceedings
1) Advances in Cryptology
2) International Conference on the Theory and Application of Cryptographic Techniques
3) IEEE Symposium on Security and Privacy
4) IEEE European Symposium on Security and Privacy
5) Usenix Network and Distributed System Security Symposium
6) ACM Conference on Computer and Communications Security
7) European Symposium On Research In Computer Security
8) International Conference on Applied Cryptography and Network Security
9) International Conference on Practice and Theory in Public Key Cryptography
10) International Conference on Information Security and Cryptography
11) Selected Areas in Cryptography
12) IMA International Conference on Cryptography and Coding
13) IEEE Symposium on Foundations of Computer Science
14) International Conference on Availability, Reliability and Security
15) Post-quantum cryptography
16) International Symposium on Foundations & Practice of Security
17) IEEE International Conference on Pervasive Computing and Communications
18) IEEE Computer Security Foundations Symposium
19) IEEE International Symposium on Network Computing and Applications
20) IEEE Consumer Communications and Networking Conference
21) IEEE Symposium on Computers and Communications
22) ACS/IEEE International Conference on Computer Systems and Applications
23) ACM International Conference on Emerging Networking Experiments and Technologies
24) ACM Symposium on Applied Computing
25) International Conference on the Theory and Application of Cryptology and Information Security

E. SEARCH AND SELECTION

In the course of the search and selection process, a total of 51,605 hits were retrieved from the resources specified in Table 2 by applying our search strings (see Listing 1). We set the number of items from each resource to 500, as it turned out that there were no other relevant matches regarding the specified search term found after this limit.

We made an exception to this approach for conference proceedings, where we conducted a manual search without

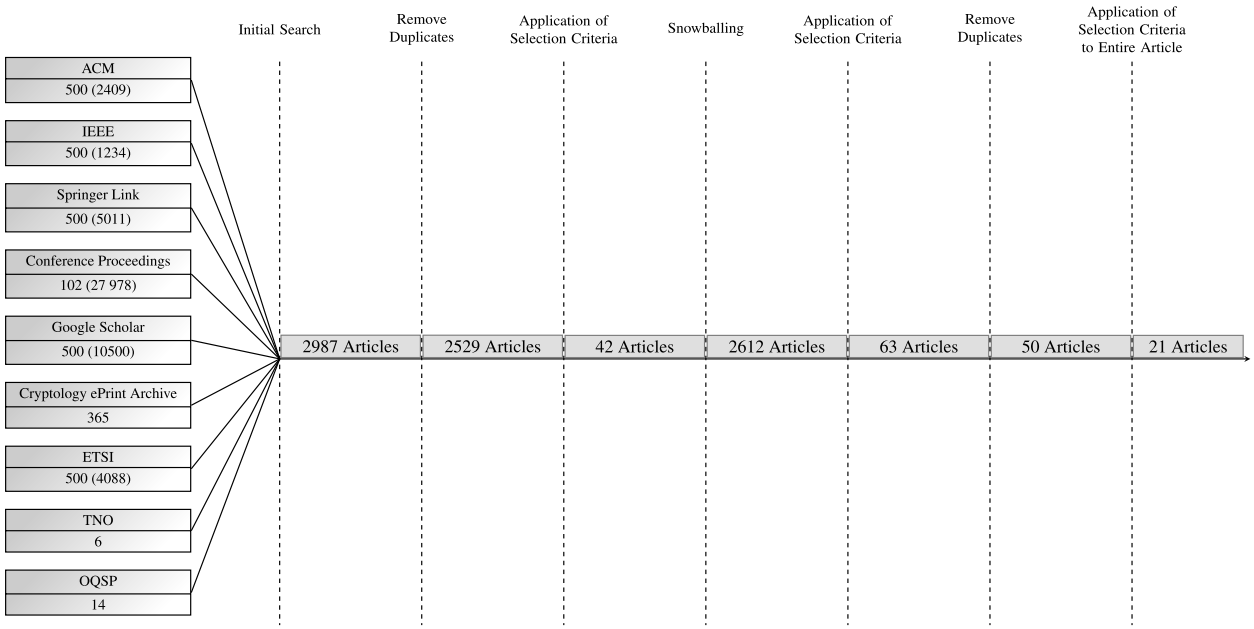


FIGURE 2. Conducting the search and selection.

a predefined search string on the corresponding conference pages of *DBLP*.[1] We selected the conferences based on the *CORE ranking portal*,[2] which provides a quality assessment for conferences.

We chose 25 conferences (see Table 2), ranging from A* to C ratings. Out of a total of 27,978 conference findings, we deemed 102 relevant based on our search string. The analysis of conference proceedings was restricted to the last 12 years, ensuring the inclusion of all articles published from 2012 onwards.

Figure 2 illustrates the search and selection procedure, which is explicated below. Following the initial search that yielded 2,987 articles, duplicates were removed. Subsequently, the inclusion and exclusion criteria were first applied to the titles and keywords of the remaining 2,593 articles. Then, selection criteria were applied to the abstract and conclusion followed by applying them to the overall article structure, i.e., to their section titles, in the subsequent step. Backward snowballing was conducted next, incorporating all references of the remaining articles, with the goal of discovering additional relevant articles beyond our initially searched resources. The selection criteria were again applied to the articles added through snowballing, followed by the removal of duplicates. As a final step, the selection criteria were applied to the entire text, necessitating a comprehensive reading of each individual article. This comprehensive process resulted in the creation of the final paper set, consisting of 21 papers.

[1]https://dblp.org/
[2]https://www.core.edu.au/

F. DATA EXTRACTION AND SYNTHESIS

Once we had identified the relevant publications, we extracted and analysed the data contained in them systematically using thematic coding. The *data extraction categories* we defined are described in Section II-F1 and used for the actual *data extraction* detailed in Section II-F2. Finally, we describe the *data analysis* and *synthesis* in Section II-F3.

1) DATA EXTRACTION CATEGORIES

Data extraction categories allow us to map content to the research questions. We used a mixture of predefined categories and emergent categories identified during thematic coding. In the following, we present the final set of categories used to code the papers in the final set.

Multiple categories are assigned to each RQ and are recorded in Tables 4, 5, and 6. Table 4 shows the categories Diagnosis, Plan, Execution, and Maintenance for RQ1 which, from the literature's and our point of view, reflect the four central phases of migration. Table 5 shows the technical applications of PQC that have played a key role in the migration so far. It shows which software systems have been migrated, which standards should be and have been adapted, as well as the extent to which hybrid migration plays a role in the literature. Last but not least, Table 6 lists the challenges that arise during such a migration.

2) DATA EXTRACTION

The objective of this activity is to extract all relevant information to answer our research questions. The loop shown in the process described in Section II-A symbolizes that we conducted this process iteratively. We did the final thematic coding of all papers with the final set of categories by marking

TABLE 3. Quality assurance plan.

Definition of Research Questions
1) The first author defines the research questions 2) All other authors review the research questions 3) They discuss disagreements until they reach a consensus
Definition of Search Strategy Procedure
1) The first author defines the search strategy including the search engine, databases, conference proceedings, as well as the search terms and steps 2) The other authors review the search strategy 3) They discuss disagreements until they reach a consensus
Definition of Inclusion and Exclusion Criteria
1) The first author selects inclusion and exclusion criteria based on the reference set and research questions 2) The second and third author review the criteria 3) All authors adjust the criteria until they reach a consensus
Definition of Data Extraction Criteria
1) The first author selects the data extraction criteria 2) The second and third author review the criteria 3) All authors adjust the criteria until they reach a consensus
Selection of Primary Studies
1) The first author selects primary studies 2) The second author independently verifies that the defined search strings yielded all papers of the reference set
Random Assessment of Included / Excluded Publications
1) Select a random sample (roughly 10%, depends on the overall amount of papers) of the search results 2) The second author applies the inclusion and exclusion criteria independently on the selected publications 3) Compare the results to the results of the first author 4) They discuss disagreements until they reach a consensus 5) If both authors consent to the selection in most cases they proceed with the process, otherwise they repeat this step If there is still disagreement discuss a consensus. Then, the first author applies the in- and exclusion criteria on the whole search result. Afterwards, start with point 2 again.
Development of a Common Data Extraction Understanding
1) The first two authors choose a paper of the reference set 2) Both authors perform the data extraction 3) Both authors compare their results of the data extraction 4) They discuss disagreements until they reach a consensus 5) Redo step 1-4 for two more papers of the reference set
Random Quality Check of Data Extraction
1) Select a random sample (roughly 10%, depends on the overall amount of papers) of included publications 2) The second author checks the quality of the data extraction in accordance with the research questions 3) Compare the results to the result of the first author 4) Either both authors agree on the extraction in general or they find a new consensus and then the first author manually examines the rest of the publications (90%) afterwards

TABLE 4. Data extraction criteria corresponding to research question RQ1.

Migration Steps (RQ1)	
Diagnosis	Asset Identification Risk Assessment Cryptographic Identification Cryptographic Assessment
Plan	Cryptographic Prioritization Migration Plan
	Execution
	Maintenance

TABLE 5. Data extraction criteria corresponding to research question RQ2.

Applications of PQC (RQ2)	
Hybrid Migration	Claimed Recommended Mentioned
Migrated Software System	Nginx DB2 PostgreSQL IoT Infrastructure Enterprises ROS Blockchain Messenger CA Microservices
Adjusted Technology	IBE TLS SSH S/MIME PGP X.509 OCSP CMP EST IPsec

and annotating the PDFs of the papers in the final paper set. We then extracted all coded information into an online whiteboard.

3) DATA ANALYSIS AND SYNTHESIS

We performed a vertical data analysis with the intention of assigning the extracted data to the corresponding extraction categories. For this purpose, we carried out a content analysis by collecting, examining, and summarizing the data and trying to identify trends. The quantitative part of the analysis involved providing descriptive statistics to ensure a better understanding. For the qualitative analysis, we analyzed the information by grouping extracts that belong together. Within these groups, we then identified similarities and differences. We used this information to identify possible patterns and trends. These findings are presented in detail in Section III.

TABLE 6. Data extraction criteria corresponding to research question RQ3.

Challenges (RQ3)	
Organizational	Education Skeptics Resource Planning
Missing / Faulty PQC Features, Guidelines or Support	Performance Issues System Downtime HW Resources
Code Base & Documentation	Large & Complex Hard Coding Legacy Encryption Legacy Environment In Flux Large Configuration
Cryptographic Inventory	

III. RESULTS

In this section, we present an analysis of the selected articles. First, we provide an overview of descriptive statistics of the articles in Section III-A. Subsequently, we will answer our three research questions in Section III-B (migration steps), Section III-C (technological modifications), and Section III-D (challenges) respectively.

A. DESCRIPTIVE STATISTICS

In this section we present the descriptive statistics of the articles with the help of Table 7.

1) LITERATURE

The first criterion is the type of literature of the 21 selected articles. This gives us an initial impression of the scientific quality of the articles. We differentiate between preprints, peer-reviewed, and gray literature.

All articles that are neither peer-reviewed nor preprints belong to gray literature. The main reason for the introduction of preprints as a subcategory lies in the special nature of manuscripts intended for a scientific audience. In contrast to other forms of gray literature, a preprint is characterized by a specific writing style tailored to scientific communication. Ten of the 21 articles are gray literature, three articles are currently available as preprints, and the remaining eight articles have been peer-reviewed.

2) AUTHOR AFFILIATION

The credibility and potential bias of the extracted data are significantly influenced by the authors' affiliations. We established the three categories academia, industry, and standardization body (e.g., European Telecommunications Standards Institute) as suitable criteria. Within the literature, instances exist, as exemplified by [20], where authors span all three categories. Conversely, articles such as [9] or [11] illustrate cases where authors exclusively affiliate with standardization bodies or universities. In 13 of the present articles, some of the authors are employed in academia, while in ten articles several authors belong to the industry. In six articles, some of the authors belong to standardization organizations.

3) VALIDATOR

We define the term validator as the entity incorporated into a paper's methodology to authenticate and validate its results. We differentiate between 3rd party, committee, and the authors of the article. By 3rd party we mean a group of experts and researchers in the field who are independent of the authors. This criterion is met for all eight peer-reviewed articles. Committee refers to a group of experts in the field who, in contrast to 3rd party, do not have to be independent. This means that the authors and other contributors can also be part of the committee. The final instance are the authors themselves, who validate their own results. Six articles are assigned to the committee and seven to the authors.

4) CONTRIBUTION

The contribution criterion categorizes the various articles according to their scope as either guidelines or frameworks. In our case, frameworks describe the content in detail, whereas guidelines present the content briefly and concisely. An example of a framework is Attema et al. [20], who describe the process, personas, and technology of the migration in great detail. ETSI's article [2], on the other hand, presents the migration steps, roles, and technical contexts in a brief and concise manner and was therefore classified as a guideline.

5) REALIZATION

According to our definition, an illustration serves as a conceptual representation of migration, while an exemplar offers insights predominantly from the viewpoint of practical execution.

Tueno et al. [5] and Zhang et al. [7] are examples for papers categorized as exemplars, as the focus of both articles is on the concrete execution of the migration by using a selected software system as a use case. Ma et al. [1] and von Nethen et al. [13] illustrate the migration and the associated aspects but do not apply them to a specific case. In our opinion, Hasan et al. [8] is the only article that focuses on both the illustrative and the exemplary part in sufficient detail.

6) FOCUS

Using "focus", we categorize articles by whether they describe the migration from an organizational perspective or from a technical perspective. With organizational focus, the process, roles, as well as challenges, costs, and effort of the migration are considered in particular, as is the case with von Nethen et al. [13]. With technical focus, the technical standards (e.g., protocols), the software systems, and the technical modifications are explained in detail and might be implemented in a concrete use case. Apart from Zhang et al. [7] and Hasan et al. [8], the remaining articles

TABLE 7. Classification of all papers according to our descriptive statistics criteria.

Ref	Literature			Author Affiliation			Validator			Contribution		Realization		Focus	
	Peer-Reviewed	Preprint	Gray	Academia	Industry	Standardization Body	3rd Party	Committee	Author(s)	Guideline	Framework	Illustration	Exemplar	Organizational	Technical
[1]	•				•		•				•	•		•	
[2]			•			•		•		•		•		•	
[3]	•			•	•		•			•			•		•
[4]			•	•					•	•			•		•
[5]	•			•	•		•			•			•		•
[6]		•		•					•	•			•		•
[7]	•			•	•		•			•			•	•	•
[8]		•		•	•				•		•	•	•	•	•
[9]			•			•		•		•		•		•	
[10]			•			•		•		•		•		•	
[11]			•	•					•	•			•		•
[12]	•			•			•			•		•			•
[13]		•		•					•		•	•		•	
[14]	•				•		•				•		•		•
[15]	•			•	•		•				•		•		•
[16]	•			•	•		•				•		•		•
[17]			•			•		•		•		•		•	
[18]			•			•		•			•	•		•	
[19]			•	•					•	•		•		•	
[20]			•	•	•	•		•			•	•		•	
[21]			•		•				•	•			•	•	•
∑	8	3	10	13	10	6	8	6	7	13	8	11	11	12	12

primarily describe the migration from either an organizational or technical perspective.

B. RQ1: MIGRATION STEPS

We find that PQC migration is structured into several steps. Additionally, most reviewed papers define a *migration team* consisting of experts and managers of the to be migrated software system or infrastructure. This team drives the migration process and cares for its completion.

1) MIGRATION STEP TERMINOLOGY

The literature neither provides a common understanding of how fine-grained the definition of the migration steps should be, nor about their terminology. This makes a comparison of their respective migration processes difficult. Thus, we first define our migration step terminology. Afterwards in Section III-B2, we map the literature to our definitions, thus validating our schema. We concluded that the following definitions fit the overall literature best:

Diagnosis is the first phase where the migration team collects information about the infrastructure. It is necessary to plan and conduct the migration.

Planning comprises the planning of the migration process considering the previously collected information.

Execution consists of the actual migration, ideally according to the previously generated plan.

Maintenance is an ongoing phase starting together with the execution. It is motivated by the fact that the considered infrastructure will change over time, both during the execution phase and afterwards. Thus, the inventories must be adapted over time and the infrastructure adjusted.

For a more detailed analysis, we divide the phases into separate concrete steps according to what is reported in the surveyed literature.

Diagnosis comprises the following:

Asset Identification is the step in which all assets of an infrastructure are identified. The result is a structured artefact (e.g. a list) of all relevant assets of the enterprise, also called an *asset inventory*.

Risk Assessment comprises an analysis of all assets regarding the cost or damage a potential attacker could cause and the chances of their success. This also feeds into the asset inventory or can be a separate artefact.

Cryptographic Identification is the step where all the assets' cryptography, e.g., which hash functions, symmetric and asymmetric encryption, or certificates and their implementations, is collected and recorded in a *cryptographic inventory*.

Cryptographic Assessment is the last preparation step and consists of an analysis of the applied cryptography, especially in the context of a quantum threat. The result enhances the cryptographic inventory.

With the asset and cryptographic inventory as well as the risk analysis at hand, we can now start the *Planning Phase* with the following steps:

Cryptographic Prioritization gives each asset and its cryptography a priority, considering its corresponding risk assessment result and potentially also other factors such as cost of migration or external dependencies. This information is compiled into the existing inventories.

Migration Plan is the step in which the team creates the actual plan and timeline for the migration. The result is a document containing at least the information who migrates what and when.

We expect the *Execution and Maintenance Phases* to be complex and tedious. Yet, their dynamic nature and dependence on the previous phases' results makes it hard to give them more static structure. The lack of detailed descriptions of these phases in the literature is also an indicator that the research community can still benefit from further research into this direction.

2) MIGRATION STEPS IN THE LITERATURE

With the migration phases defined, we can now structure the literature according to the steps it considered. This means we mapped the migration steps to our definitions and terminology. Table 8 shows the results of the mapping and which papers focussed on what topics. In the following paragraphs, we will describe the differences in the definitions of the steps' in the literature compared to ours.

In general, the most documented migration step is *Diagnosis*. Within Diagnosis, most papers mention the compilation of the cryptographic inventory, but provide very few details on how to do this practically. In addition, their definition of what the cryptographic inventory should comprise differs. Some papers see it as an inventory purely for cryptographic assets [19]. Other papers split the inventory into several sub-inventories [8], [9], [10], [20], [21], e.g., a data inventory. The ETSI [2] additionally differentiates between an organization's data, its infrastructure, and its supplier inventory [2]. Since the cryptographic inventory is a key artifact in any PQC migration, this lack of concrete guidance is a serious research gap.

The reviewed literature showed more agreement regarding the *Planning Phase*. While the papers differ in terms of granularity, the ETSI [2] stands out again. In addition to the common prioritization and planning steps, it also gives advice on planning for failure or disorderly transition. It mentions that some assets may need to be isolated or at least kept in different zones, as migrating them (early) might not be feasible. Finally, it discusses trust and key management during migration [2].

For the *Execution Phase* the literature is rather sparse, possibly since there is still a lack of experience regarding actual PQC migrations. The papers that do cover the execution phase mostly stress the importance of transitional solutions for successfully conducting the migration without increasing the overall risk. These include the addition of pre-shared keys [20], testing the compatibility with just a small set of systems first [13], isolating hard-to-migrate assets from the network [2], and, most predominantly, using hybrid cryptography schemes [3], [20], [21].

The last phase is the *Maintenance* or *Remediation Phase*. It is also not covered extensively in the literature, probably for the same reason as the execution phase. The papers that do address this phase mention three aspects: 1) The most prominent one is that an organization must not make the mistake to only allocate resources for the migration itself without considering the maintenance of the new or changed infrastructure [7], [8], [20]. 2) For management it is usually important to have information about the success of the migration. Thus, it is necessary to track the costs and measure the impact of the conducted migration steps [7], [13]. 3) Documenting the lessons learned in order to improve the subsequent PQC migration steps and future migrations, especially since PQC is currently a fast moving technology [7].

Seven papers do not address any of the migration phases of Table 8. Those papers focus on technical aspects of the migration of specific software. Since they all migrated a specific system which is not in productive use, the migration's organizational impact is no topic in those papers. Instead, the authors usually chose a generic software development approach. This includes analyzing the software, searching a way to solve the given problem, hence, integrating PQC, implementing their preferred solution, and finally evaluating their result, ideally against predefined metrics. Thus, these papers do not give insight into the topic of how to manage the migration of complex distributed systems or infrastructures which are currently in use. Still, we deem them an important contribution to the literature about PQC migration, due to their information about the challenges and possible solutions specific for developing PQC-ready software.

3) ROLES IN MIGRATION

The team driving the migration has to include several roles to have both the expertise and the authority within the organization to successfully complete the migration process. Most papers that do consider these roles define them including their names, necessary skills, and competences. Only Muller and Heesch [10] leave it at declaring their skills. We clustered the literature's role definitions into four archetypes: 1) *Migration Manager*, 2) *Asset & Risk Manager*, 3) *Security Expert*, 4) *Developer or Administrator*.

Most of the literature that covers the roles involved in the migration process mention at least one aspect of each role that is important for the migration team. Table 9 shows the exact coverage of each paper regarding the role archetypes.

For the *Migration Manager* archetype, the literature mostly agrees on wording and responsibilities. Other terms in the literature are ''Executive Officer'' [13], ''IT-Manager'' [21], and ''Business & Technology Manager'' [19]. Regarding skills and responsibilities, Muller and Heesch [10] expect purchasing experience, legal knowledge, and knowledge about

TABLE 8. The migration steps according to our definitions and how the literature covers them. We removed all papers which did not address the migration procedure.

Ref	Diagnosis				Plan		Execution	Maintenance
	Asset identification	Risk assessment	Cryptographic identification	Cryptographic assessment	Cryptographic Prioritization	Migration Plan		
[1]	•	•	•	•		•		
[2]	•	•	•	•	•	•	•	
[3]							•	
[7]	•				•	•	•	•
[8]	•	•	•	•			•	•
[9]	•	•	•	•	•	•		
[10]	•		•	•				
[12]						•		
[13]	•		•			•	•	•
[16]							•	
[18]					•			
[19]		•	•			•		•
[20]	•	•	•	•	•	•	•	•
[21]	•	•	•	•	•	•	•	
$\sum$	9	7	9	7	6	9	8	5

TABLE 9. The role coverage of the reviewed papers regarding our archetypes. All papers that do not mention roles are not listed.

Ref	Migration Manager	Asset & Risk Manager	Security Expert	Developer or Administrator
[2]	•	•	•	•
[7]				•
[10]	•	•	•	•
[13]	•	•	•	•
[19]	•	•		
[20]	•	•	•	•
[21]	•		•	•

the organization. Attema et al. [20] see strategy and policy creation as their most important task and von Nethen et al. [13] expect them to be project leaders.

The *Asset & Risk Manager* archetype is also called "Technology Executive" [19]. Muller and Heesch [10] and Attema et al. [20] implicitly define such a role by expecting knowledge about the organization's data and assets. As further responsibilities of this archetype, von Nethen et al. [13] request them to do the risk assessment. According to Attema et al. [20], these roles should also be strategy and policy makers.

The main responsibilities of the *Security Expert* archetype are knowledge about cryptography and the organization's network architecture as well as its assets [10]. Furthermore, these roles should decide how cryptography is to be migrated [20] and should educate the organization about PQC and its importance [13].

The migration has to be planned meticulously to be successful, but also executed with precision and competence. For this the *Developer or Administrator* archetype is especially important as noted by all but one paper. Additionally, these roles should also have knowledge about the organization's network architecture and cryptography [10]. According to Attema et al. [20], they should take part in the decision how cryptography needs to be migrated.

Every role archetype which is part of the migration team has to be at least informed about everything happening in each migration step. In most cases, we expect them to also be consulting the team, thus contributing their expertise. Still, each archetype will be associated with migration steps for which they are responsible. Deducing from the literature's definitions of both the migration steps and roles, we assigned a responsible archetype to each migration step as shown in Table 10.

Despite the Migration Manager being responsible for only one migration step, they are accountable for all of them and are the main role to communicate the team's decisions and needs to the organization's management.

TABLE 10. The matching of migration phases and the roles responsible for them respectively.

Step	Migration Manager	Asset & Risk Manager	Security Expert	Developer / Administrator
Asset Identification		•		
Risk Assessment		•		
Cryptographic Identification		•		
Cryptographic Assessment			•	
Cryptographic Prioritization			•	
Migration Plan	•			
Execution				•
Maintenance		•		•

The Security Expert and the Developer or Administrator archetypes have responsibility for only two migration steps, as well. Yet, they are both consulting in almost all other steps. Thereby, the Security Experts' knowledge helps to build a secure solution with as little security flaws as possible and the Developers' and Administrators' involvement is necessary to plan a solution that can actually be realized afterwards.

RQ1 Summary

We identified the four phases "Diagnosis", "Plan", "Execution", and "Maintenance" as the fundamental phases for migrating software systems towards PQC. We concretized Diagnosis by splitting it up into the identification of assets, risk assessment, cryptographic identification, as well as cryptographic assessment. The planning phase contains the cryptographic prioritization and the planning for the migration.
We determined that "Migration Manager", "Asset & Risk Manager", "Security Expert", and "Developer/Administrator" are the four key role archetypes for the migration and mapped the archetypes to the appropriate migration steps. With this approach we unified the literature and provide a consensus.

C. RQ2: APPLICATIONS OF PQC

Research question RQ2 deals with the current applications of PQC in the context of our final paper set. This includes the consideration of hybrid migration, the migrated software systems, as well as the adapted standards, protocols, and schemes.

1) HYBRID PQC

After successful migration, PQC is either used in full or hybrid form. Full PQC means the usage of cryptography that is currently considered quantum-resistant only. The general consensus for the meaning of hybrid in this context refers to the combination of quantum-resistant and classical cryptography [10], [36], [37]. This applies both to digital signatures and to key establishment [10]. Attema et al. [20] coins the term "Hybrid AND" for this type of hybrid. Furthermore, they define "Hybrid OR" as the use of either quantum-resistant or classical cryptography, which can ensure backwards compatibility.

Our review reflects the extent to which hybrid approaches play a role in the literature. In this context, we do not distinguish between the two types of hybrids. Instead, we draw a distinction based on whether the individual articles assert the implementation of either of these two approaches, advocate for their adoption, or simply mention the viability of hybrid solutions. This is illustrated in Table 5.

For reasons of clarity, an article is only assigned to one of the three sub-categories. Articles falling under the *claimed* category explicitly mention hybrid solutions. Six of the 21 articles claim to provide a hybrid solution by using hybrid certificates [3], signature schemes [4], [11], [15], [21], or key establishment [5], [11], [21] after the migration. Three articles advocate for a hybrid solution, while an additional six articles merely mention it as a potential implementation option. Notably, in the remaining articles, comprising almost a third of the total, hybrids are not referenced in any manner.

2) MIGRATED SOFTWARE SYSTEM

We now illustrate the variety of software systems for which a PQC migration was executed. The systems range from web servers via operating systems all the way through to databases. It turned out that ten of the 21 articles describe an actual PQC migration. We therefore created a simple classification (see Table 11) on whether the migration was either carried out successfully (criterion applies), described theoretically (criterion described theoretically) or failed (criterion failed).

Hybrid solutions were implemented for the migration of the Nginx web server, a certification authority (CA), the Hyperledger Fabric blockchain framework, and the PostgreSQL database management system, whereas hybrid processes were only mentioned as a possibility for Db2 but were not discussed further. Holcomb et al. [15] also claim that Hyperledger Fabric's quantum-safe solution called PQFabric is fully crypto-agile, by which they mean that the used cryptography can be flexibly replaced by other post-quantum cryptographic standards.

Weller and van der Gaag [4] attempt to make Apache Kafka quantum-resistant. However, this was not possible due to

TABLE 11. Classification of all papers according the application of PQC.

Ref	Hybrid PQC			Migrated Software System									Adjusted Standard									
	Claimed	Recommended	Mentioned	Nginx	IBM DB2	PostgreSQL	IoT ecosystem	ROS	Hyperledger Fabric	Delta Chat	Certification Authority	Apache Kafka	IBE	TLS	SSH	S/MIME	PGP	X.509	OCSP	CMP	EST	IPsec
[1]																						
[2]			●															○				
[3]	●										●							●	●	●	●	
[4]	●											×		○								
[5]	●					●								●								
[6]													●									
[7]			●		●									●								
[8]																						
[9]			●																			
[10]			●																			
[11]	●			●																		
[12]							○															
[13]		●																				
[14]								●										●				●
[15]	●								●									●				
[16]										●						●	●					
[17]			●																			
[18]			●				○															
[19]		●																				
[20]		●												○	○	○	○	○				○
[21]	●																					
∑ ●	6	3	6	1	1	1	0	1	1	1	1	0	1	2	0	1	1	3	1	1	1	1
∑ ○	0	0	0	0	0	0	2	0	0	0	0	0	0	2	1	1	1	2	0	0	0	1
∑ ×	0	0	0	0	0	0	0	0	0	0	0	1	0	0	0	0	0	0	0	0	0	0

● Criterion applied ○ Criterion described theoretically × Criterion failed

integration issues with the PQC libraries *Wildfly-OpenSSL*,[3] *Bouncy Castle*,[4] and *Open Quantum Safe OpenSSL*.[5] For their PQC performance evaluations, the authors relied on the pre-built PQC client and PQC server solutions of the Open Quantum Safe (OQS) project, which provides automatically working hybrid solutions. However, we consider the actual attempted Kafka migration to have failed, which is why we have marked it accordingly in the table.

3) ADJUSTED STANDARD

In addition to the analysis of migration types and migrated software systems, our examination focuses on the cryptographic standards that were modified during the migration process. It was ensured that only articles that describe the adaptation of the standard in detail and in depth are included as "criterion described theoretically".

Attema et al. [20] describe in detail why and how TLS, SSH, S/MIME, PGP, X.509 and IPsec must be adapted to ensure quantum resistance. Fan et al. [3] describe the concrete practical implementation for the migration of a Certificate Authority (CA) in depth using the modifications of X.509, OCSP, CMP, and EST. In addition, they are the only ones that fully address the necessary technical specifications for the process of issuing, exchanging, and verifying certificates in the context of the aforementioned protocols and have successfully implemented the migration. While the ETSI [2] describes the PQC extension of the X.509 standard in theory, Varma et al. [14] and Holcomb et al. [15] deal with the practical implementation of the extension of the X.509 certificate. However, these articles do not highlight the wide-ranging relationships between the various components and protocols compared to the article by Fan et al. [3], which is why they are represented in the table as X.509.

In addition to the Delta Chat messenger, its email infrastructure was also made quantum-resistant, as messages are also sent via the user's email [16]. Specifically, the two

[3]https://github.com/wildfly-security/wildfly-openssl
[4]https://www.bouncycastle.org/specifications.html
[5]https://github.com/open-quantum-safe/oqs-provider

encryption protocols S/MIME and PGP were successfully adapted for this purpose. For the actual implementation, rpgp CRYSTALS-Kyber, CRYSTALS-Dilithium and Picnic were added as public-key encryption and digital signature schemes. For S/MIME, on the other hand, the *botan*[6] library was extended to include PQC.

The Robotic Operating System (ROS) was made quantum-safe by adapting it at both application and network level [14]. RSA was replaced by Bimodal Lattice Signature Scheme (BLISS) as the signature scheme, the previous IPsec VPN `racoon` by the quantum-resistant *strongSwan*[7] IPsec VPN [14].

For both database management systems PostgreSQL and Db2, PQC was integrated on both the client and server side. For Db2, CRYSTALS-Kyber was used as key exchange and CRYSTALS-Dilithium as signature scheme [7]. TLS 1.3 was integrated for both client and server, which was provided by *IBM Global Security Kit (GSKit)*.[8] For PostgreSQL, the quantum-safe OpenSSL version of Open Quantum Safe was used for the digital signatures as well as for key exchange [5]. Furthermore, the ECDH specifications were hardcoded and had to be adapted.

For identity-based encryption, quantum-secure lattice cryptography (DLPlattice) was integrated as part of an exemplary REST service. For this purpose, the open-source C-library *MIRACL*[9] as well as custom wrappers and library implementations were used to ensure the necessary functionality for IBE [6].

RQ2 Summary

PQC solutions, like quantum-resistant key exchanges and digital signature schemes, were integrated in ten different software systems, ranging from robotic operating systems to web servers or messengers.
The migration was conducted by exchanging or enhancing classic cryptographic standards like TLS, S/MIME or X.509, using either proprietary (e.g., IBM Global Security Kit) or open source libraries (e.g., liboqs) that offer implementations of algorithms that are currently considered quantum-resistant.
Over half of the migrated systems use hybrid solutions after the transition, making it possible to rely on a combination of classic and post-quantum cryptography.

D. RQ3: CHALLENGES

This research question aims to ascertain the challenges associated with the migration of software systems towards post-quantum cryptography. In contrast to other works that only superficially deal with the challenges of PQC migration, our selected articles are based on practical experience and in-depth theoretical descriptions that specifically address the challenges that arise.

First, we look at the challenges that organizations face as a result of a PQC migration. Then, we will take a closer look at the challenges that post-quantum cryptography poses at the current point in time. Finally, we present the challenges that can arise from an existing code base and documentation of a software system. In particular the articles [7], [8], [11], [12], [13] deal with the various challenges and accordingly are the source for a large part of the findings. Table 12 represents the challenges as well as their subcategories.

TABLE 12. The challenges according to our definitions and how the literature covers them. Papers not listed did not address any migration challenges.

Ref	Organization			PQC				Code and Documentation			
	Education & Expertise	Time Effort & Costs	Sceptics	Hardware Requirements	Performance & Availability	Security Concerns	Support & Features	Complexity, Variety & Magnitude	In Development	Legacy Encryption & Environment	Weakness & Error-Proneness
[2]		•									•
[4]							•				
[5]				•							
[7]	•	•		•				•	•	•	•
[8]	•	•		•				•	•	•	
[10]		•				•					
[11]	•	•	•		•		•	•			
[12]		•	•	•	•		•			•	
[13]	•	•			•	•		•			•
[15]							•				
[16]							•				
[19]		•									
[20]		•				•		•			
∑	4	9	2	4	3	3	5	5	2	3	3

1) ORGANIZATION

We have identified the three subcategories *Education & Expertise*, *Planning*, and *Sceptics* as representatives for the organizational challenges.

Education & Expertise refers to the lack of expertise in the PQC environment, as well as the difficulties of providing the best possible education to all affected employees. It is regarded as an essential prerequisite prior to commencing the realization, as indicated by the articles mentioned above [7], [8], [11], [12], [13], addressing this subcategory.

The subcategory *Time, Effort & Costs* refers to challenging resource planning. Attema et al. and Zhang et al. [7], [20] emphasize this observation considering the prevailing uncertainty. In addition, the identification of stakeholders and

[6]https://github.com/randombit/botan
[7]https://github.com/strongswan/strongswan
[8]https://www.ibm.com/docs/en/informix-servers/14.10?topic=protocol-global-security-kit-gskit
[9]https://github.com/miracl/MIRACL

the planning of communication also belong to this category. Nine of the 21 papers address this topic, making it the most frequently mentioned challenge across all subcategories.

Two articles [11], [12] describe the *Sceptics'* view of PQC, with [11] arguing this is due to unknown risk and the associated high costs. This makes sceptics the least frequently mentioned challenge in the literature.

2) PQC

The literature highlights that Post-Quantum Cryptography (PQC) itself poses various challenges, with a total of eleven different articles addressing them. Consequently, we have opted to introduce the PQC category to address these challenges. In our opinion, these challenges are best examined from the four different perspectives of *Hardware Requirements*, *Performance & Availability*, *Security Concerns*, and *Support & Features*.

Hardware requirements are increasing due to growing computational costs, a consequence of the expanding dimensions of keys, ciphertext, and signature. Hasan et al. [8] additionally describe the required replacement of numerous hardware appliances which integrate hardware acceleration for broadly used cryptosystems.

The second challenge is reflected in the overall availability of the software systems and their performance during and after the migration. Von Nethen et al. [13] emphasize that systems must remain interoperable to sustain availability across different systems. Furthermore, Suhail et al. [12] underscore the trade-off in scenarios with limited resources, balancing the challenges posed by excessive data and the need for optimal performance.

The *Security Concerns* subcategory reflects the risks that can arise from the use of current PQC. This means either the mathematical procedures on which the current PQC algorithms are based on can be broken or that the algorithms' implementations contain vulnerabilities. Muller and Heesch [10] as well as Von Nethen et al. [13] caution against downgrade attacks, where an attacker tries to divert communication between the sender and receiver to classical algorithms.

The last sub-category represents the challenges that arise with regard to *support* of the implemented PQC features. Currently, most libraries that offer PQC are under development. Some implementations are therefore still incomplete or have faulty features, such as an incomplete API or a corrupt key store, as described by Weller et al. [4] and Mohammad et al. [11]. Missing, insufficient or incorrect documentation and guidelines of current PQC implementations also pose issues. In this context, Suhail et al. [12] emphasize the lack of necessary parameter information for certain PQC schemes, which can complicate or prevent the applicability of PQC.

3) CODE AND DOCUMENTATION

The *Code and Documentation* category includes challenges that may arise from the current source code and documentation. Within this category, we have identified the following subcategories: *Complexity, Variety & Magnitude*, *In Development*, *Legacy Encryption & Environment*, and *Weakness & Error-proneness*.

Complexity, Variety & Magnitude illustrate the challenges that can arise due to a large and complex code base, configuration and infrastructure. Zhang et al. [7] describe a migration of a code base comprising tens of millions of lines of C/C++ code. Associated with this is the variety of components and diverse setup possibilities which in turn also influences the documentation.

The next subcategory *In Development* covers the challenges that can arise due to ongoing software development. This leads in particular to increasing effort to maintain an up to date cryptographic inventory [8].

The next category deals with the challenges that arise due to legacy environment and the associated legacy encryption. During the data analysis and synthesis II-F3, we saw that maintaining outdated code bases and infrastructures leads to poorer maintenance, backward compatibility, and difficult integration of encryption. As a concrete example, the use of DES in the Db2 environment can be allowed due to the need to support older Db2 clients [7].

The last subcategory represents the challenges that can arise due to poor code quality (e.g., hard-coded cryptographic functions or parameters [7]), missing or inadequate documentation [7], and the lack of encryption of assets which require protection [2].

RQ3 Summary

Organizational, post-quantum cryptographic, as well as code- and document-based challenges are the three main challenges we identified that emerge while migrating towards PQC.
While the first category illustrates challenges in PQC expertise or rising time and effort, the second category covers challenges regarding security concerns of the currently available PQC implementations as well as missing support and features. Code and documentation-based challenges can occur due to the complexity and variety of the code base or due to its legacy environment and encryption.

IV. DISCUSSION

In this section we illustrate and discuss the main takeaways of this study, which are:

1) Lack of maturity in PQC implementations;
2) Lack of an established migration framework;
3) Lack of concept and specific realization of a cryptographic inventory;
4) Sparse application of PQC;

Before we can delve into the main takeaways, we address the notion of *crypto-agility*, which is present in the majority of the reviewed papers but not in our results. The reason for this

deliberate decision is that the literature has neither a uniform nor clear definition for crypto-agility. The understanding of the term may vary from aspects like *Is the software or hardware system updatable?* or *If RSA-2048 worked for the protocol or implementation, what does that mean for the use of RSA-4096?* to the far more complex such as *If only small Diffie-Hellman exchanges were used in the protocol or implementation, can several hybrid key exchanges be integrated supporting several different key agreement schemes satisfying all requirements like computational or memory costs?*.

Similarly, literature differs widely in interpretation. For example, White et al. [21] try to further differentiate between the types of crypto-agility, while others like Mashatan et al. [19] simply recommend to invest into it, but do not address the topic in more detail. When it comes to concrete steps and recommendations to make systems more crypto-agile, the literature mentions hybrid cryptographic schemes and modular code with little technical debts, like hard-coded parameters, as desirable [13]. All these factors are already addressed in great detail in Section III.

One secondary study [29] tried to find a common definition of crypto-agility. Their conclusion is that a system or infrastructure is crypto-agile if it supports to be migrated with comparatively low effort. As a very detailed and concrete defintion for crypto-agility is hard to grasp at the time, we agree to focus on the basic question of an alleviated transition and therefore see the question of introducing more complex crypto-agile mechanisms as being redundant for now. Therefore, we focus on how to ease migration and discuss our main takeaways in the following.

A. LACK OF MATURITY IN PQC IMPLEMENTATIONS

Within the scope of RQ2 (see Section III-C) and RQ3 (see Section III-D), we identified the current PQC implementations' insufficient maturity and a lack of detail in the underlying standards. Both aspects negatively impact real-world realizations built upon them.

One of the well-established organizations is the *National Institute of Standards and Technology (NIST)*,[10] which initiated a process for evaluating and standardizing post-quantum cryptographic algorithms to provide foundational security guarantees. Despite comprehensive scrutiny, Attema et al. [20] highlight that vulnerabilities are discovered frequently in the proposed algorithms.

Besides the failings of the proposed standards, the present implementations of PQC algorithms pose a major challenge as they exhibit deficiencies such as missing or insufficient support for different programming languages and frameworks (see Section III-D2). Weller et al. [4], for example, did not manage to integrate the PQC libraries *Wildfly-OpenSSL* and *Bouncy Castle* into their microservice environment due to missing and faulty functionalities in these libraries.

A large number of PQC libraries are currently under development and are being actively maintained, such as *liboqs*[11] from the *Open Quantum Safe (OQS) project*, *Botan*, and *PQClean*.[12] Which quality they can achieve and which of them will be adopted most widely remains to be seen.

Another key consideration in this context is the provisioning of PQC libraries for embedded devices, covered in Section III-D2. Ott et al. [38] also highlight this as a key challenge due to their constrained computational power and memory size. According to Barker et al. [39], this could be possibly counteracted if the *NIST* standards take hardware constraints into account. In contrast, Ott et al. [38] criticise the *NIST* PQC submissions as not ready to use in the real-world.

To conclude this point, on the one hand it is clear that a lot of effort being put into the matter by experts in terms of theoretical as well as practical work and a wide variety of complex problems especially regarding implementation is tackled step by step. On the other hand, we see in our analysis just how difficult the field of applied cryptography is and that there is no consensus on how to approach the implementation of PQC algorithms, in particular for resource-constrained systems. We still believe that these efforts will converge into reliable and field-tested solutions and implementations, but due to the current lack of practical experience, most available implementations have to be considered experimental at this point in time.

Key Takeaway

Overall, further standardization efforts as well as mature implementations with full support for different hardware, programming languages, and frameworks are necessary to ensure an efficient realization of PQC.

B. LACK OF AN ESTABLISHED MIGRATION FRAMEWORK

Our second main takeaway is the absence of an established migration framework, which is illustrated by the results of Section III-B.

Firstly, the dissimilar terminology for the various migration steps presents a challenge. Secondly, the activities that characterize these steps are defined in highly divergent ways.

According to Cryptovision [40], the migration procedure comprises six different phases, namely the project setup, the creation of a cryptographic inventory, risk understanding, impact assessment, the involvement of executives, and the execution of the migration. Contrary to this, Alnahawi et al. [41] distinguish between algorithm migration and system migration. They briefly mention the relevance of appropriate planning, prioritization, and the creation of a cryptographic inventory in the context of system migration. This dissent is representative for the diversity we saw when analyzing our final paper set for the existing migration procedures. It underlines the importance of a unified migration process with precisely defined steps. To counteract this lack of consensus, we identified four

[10] https://www.nist.gov

[11] https://github.com/open-quantum-safe/liboqs

[12] https://github.com/PQClean/PQClean

migration phases and several sub-steps as fundamental based on the entirety of our final paper set (see Section III-B1).

We further observe that guidelines and recommendations for PQC migrations are usually brief (see, e.g., [42], [43]). These documents help the migration team with the first steps and give some direction but fall short of a well-defined, fleshed-out migration process.

In our opinion, those are major issues, which lead to practical PQC migrations often following a trial-and-error approach rather than a clearly defined procedure. We have noticed this in several studies, such as those by Holcomb et al. [15], Varma et al. [14], Mohammad et al. [11], or Weller et al. [4].

In addition to the individual activities, a description of the PQC migration process should include defined roles to ensure that the right stakeholders are involved. We condensed the role definitions of the theoretical frameworks in our surveyed literature into a clear and comprehensive role structure. Additionally, we mapped this role concept to the previously extracted and canonized role framework in Section III-B3. Still, these role assignments lack verification from real-world experience. None of the performed migrations described by our final paper set mentioned any tangible role allocation. Instead, they were mainly performed by the authors, without addressing roles.

To conclude, current migration frameworks mostly provide highly abstract descriptions. Quite often hints about the actual steps are given, e.g., by referring to some tasks and tools that might be handy in building a cryptographic inventory. Yet, a hands-on or step-by-step guide is missing and left to (the individual needs of) the reader. It is likely that these frameworks will become more concrete as more and more entities approach the migration and share their experiences. Right now, even the more detailed frameworks leave a lot of room for interpretation.

Key Takeaway

A consensus on the various migration steps and roles involved for successfully conducting a PQC migration is missing. We summarized the current status-quo of theory and practice in four steps and assigned them appropriate roles (see Section III-B2 and Section III-B3). Multiple structured and comprehensive migrations of software systems which follow our specified concept are necessary for its validation and refinement to shape an established migration framework.

C. LACK OF CONCEPT FOR AND SPECIFIC REALIZATION OF A CRYPTOGRAPHIC INVENTORY

The cryptographic inventory is an essential artifact which contains the necessary information about the cryptography used for various assets. As described in Section III-B2, most of the literature mentions the compilation of the cryptographic inventory. In particular Hasan et al. [8], Barker et al. [9], Attema et al. [20], and ETSI [2] describe the cryptographic inventory and its content in more detail.

There is a no consensus on what constitutes a cryptographic inventory and how it differs from other artifacts, such as an asset inventory. The inconsistent use of terminology in the literature which sometimes refers to processes and sometimes to artifacts, adds to the confusion and makes it difficult to develop a standardized understanding of this concept.

Beyond our final paper set, this is also confirmed by the Cryptosense SA [44] and FS-ISAC Inc. [45]. The former see the cryptographic inventory as the combination of the infrastructure and applied cryptography [44], whereas the latter simply mention the need to examine all existing inventories regarding cryptography [45].

We therefore provide a consistent terminology for the various process steps (see Section III-B1) by distinguishing between asset identification as well as cryptographic identification, evaluation, and prioritization based on the literature we reviewed.

So far, the cryptographic inventory has only been described at a conceptual and theoretical level. There is a lack of practical guidance or recommendations as to which tools are most suitable, to what extent, and under which conditions.

An initial approach for tackling this issue is provided by Cryptosense [44]. For the determination of the used cryptography (e.g., rest encryption, file verification, or password protection), they recommend performing manual scanning by reviewing code or interviewing developers, static scanning of the source or byte code, as well as run-time tracing to observe the application behaviour during execution. They propose the tool "Cryptosense Analyzer" for the static and dynamic application security testing. To determine an infrastructure's cryptography, they recommend examining the network traffic for the used protocols, the file system for certificates and keys, as well as the hardware security modules which often contain master keys of the organization. For capturing the cryptography of the network traffic, the authors suggest the tools "testssl.sh"[13] for TLS, "ssh_scan"[14] for SSH, and "ike-scan"[15] for IPsec.

To conclude, we expect the step of building a cryptographic inventory to be split into various subtasks including steps like surveys and the use of questionnaires e.g., for system administrators, network scanning in various ways, different approaches for code analysis and many more. We hope for the creation of common standards for building inventories, e.g., for a suitable data format. Similar problem statements and approaches may be found in fields like the modern *Software Bill of Materials (SBOM)* (compare e.g., the US Executive Order on Improving the Nation's Cybersecurity [46]) or the even more specific *Cryptography Bill of Materials (CBOM)*.[16]

[13] https://github.com/drwetter/testssl.sh
[14] https://github.com/mozilla/ssh_scan
[15] https://github.com/royhills/ike-scan
[16] https://github.com/IBM/CBOM

Key Takeaway

The concept of *cryptographic inventory* is currently ill-defined and used with very different meaning in the literature. What is needed are an in-depth examination of the concept, clear definitions, a unified terminology, as well as a practice-oriented design. Emerging tooling as well as related areas indicate that this area is starting to receive the necessary attention.

D. SPARSE ADAPTION OF PQC

As we have shown in Section III-C, the migration to PQC in software systems has been extremely rare. Only eleven papers mentioned concrete applications, while ten others focused on the theoretical description of the migration.

In Section III-C1, we highlighted that there are few hybrid approaches in which PQC is used in combination with classic cryptography methods. Since such hybrid approaches are recommended and mentioned so rarely, they are only used infrequently in practice.

Nonetheless, a lot of preparation has been done lately. Standardization bodies are actively working on quantum-resistant solutions. For example, many working groups within the IETF and IRTF added PQC to their work and charters (e.g., the *Crypto Forum Research Group (CFRG)* which published RFCs for hash-based signatures [47], [48] or *Limited Additional Mechanisms for PKIX and SMIME (LAMPS)* which made PQC an explicit charter point[17]) and even an explicit post-quantum working group *Post-Quantum Use in Protocols (pquip)*[18] was founded. Also, first PQC-related protocol extensions have been published, e.g., by the *IP Security Maintenance and Extensions (ipsecme)* group [49], [50]. Yet, they have also met significant criticism for their approaches [51] and first implementations are sparse and sometimes do not necessarily comply to the full extend or all details of the standard[19] (compare, e.g., strongSwan).

NIST expects to publish the first post-quantum FIPS standards[20] in the course of 2024. The only encryption scheme that will be standardised, recommended, and required by regulative means is Kyber aka ML-KEM. Other agencies, such as the German BSI, announced that despite having different recommendations as of now, they will likely adopt at least some aspects of the coming NIST standards like approving Kyber aka ML-KEM (for NIST security levels 3 and 5) [52]. We thus expect this to be the starting point of a wider adoption in practice, as many initial solutions will then focus on NIST-approved algorithms as long as they are practical enough for real-world use. This can be seen already, e.g., regarding drafts proposed to the IETF (compare Julien et al. [53], Schwabe et al. [54], Turner et al. [55], Westerbaan et al. [56] to name just a few).

To conclude, we see more and more PQC standards being published or heading for publications. We hope for a kind of domino or snowball effect once the first solutions found their way into practical use. The additional experience will help to improve the post-quantum solutions and lead to even further spread of use.

Key Takeaway

Few standards regarding PQC exist with many on the way. For the ones that already exist, practical adoption is sparse, e.g., due to the implementational complexity needed for extending existing standards and implementations. A faster development is expected, once regulative authorities like NIST release first standards and recommendations.

V. THREATS TO VALIDITY

We follow Ampatzoglou et al. [57] in categorizing the relevant threats to validity of our study. They split the threats to validity for a secondary study such as our SLR into three categories: *study selection validity*, *data validity*, and *research validity*. Most of the threats listed by Ampatzoglou et al. are addressed in our *quality assurance plan*, shown in Table 3. In addition, we followed the PRISMA 2020 statement [31] to ensure that we used current state-of-the-art methods throughout our study.

A. STUDY SELECTION VALIDITY

The process illustrated in Section II addresses most of the threats to validity Ampatzoglou et al. list in this category. In particular, we have used several mitigation mechanisms to make sure we identify relevant studies, including mixing digital libraries as well as venues, using pilot searches and snowballing. We also consider how we have applied inclusion and exclusion criteria as rigorous since we performed random screening and comparison. We have not considered sources not written in English, but do not consider this a shortcoming since we only found very few resources in other languages.

B. DATA VALIDITY

Our final paper set is relatively small with 21 papers, but also highly relevant for our research questions. It covers a broad set of venues as well as grey and academic literature. We therefore consider it representative and sufficient to answer our research questions. While we did not perform quality assessment of the articles, our inclusion and exclusion criteria were designed to only include papers that have a research character and provide concrete methodologies, frameworks, etc., thus excluding many lower-quality publications such as marketing material. As detailed in our quality assurance plan, data extraction has been performed by several researchers and

[17] https://datatracker.ietf.org/wg/lamps/about/

[18] https://datatracker.ietf.org/wg/pquip/about/

[19] https://datatracker.ietf.org/meeting/111/materials/slides-111-ipsecme-combined-slideset-01

[20] https://www.nist.gov/news-events/news/2023/08/nist-standardize-encryption-algorithms-can-resist-attack-quantum-computers

we have performed random quality checks to ensure unbiased data extraction.

C. RESEARCH QUALITY

We have documented our research process extensively and make it available in our supplementary material. This includes the research protocol that we have followed and reported in Section II. We believe the chosen research method is suitable for answering our research questions since it was our explicit and stated goal throughout to understand the state-of-the-art and the state-of-the-practice as reported in the literature. We use related work throughout this report, but in particular in Section IV where we discuss our findings in relation to the related work. We also believe our study to be generalizable as we capture a broad understanding of the current literature.

VI. CONCLUSION

In the face of potential threats posed by quantum computers the urgent need for quantum-safe cryptographic solutions is evident. Despite global efforts to develop such solutions, migrating the extensive and diverse software systems of today's digital infrastructures towards post-quantum cryptography remains a substantial challenge. We, therefore, conducted a systematic literature review according to the well-established PRISMA 2020 statement [31].

The contribution of this paper is a comprehensive overview and entry point into the complex topic of PQC migration. We provide insights into the current state-of-the-art and state-of-the-practice and distill knowledge from a number of academic and grey sources. In particular, we provide the first generic description of a post-quantum migration process (RQ1), an overview of which applications have already been migrated to PQC (RQ2), and investigate the challenges that arise during the migration process (RQ3).

In RQ1 we identified ''Diagnosis'', ''Plan'', ''Execution'', and ''Maintenance'' as the four fundamental phases comprising more concrete steps for migration based on the literature. Additionally, we delineated four essential key roles for migration and mapped each role to its corresponding step in the migration process.

In RQ2, we illustrated ten already migrated software systems and highlighted the impact of hybrid solutions in this context. These migrations involved the substitution or enhancement of traditional cryptographic standards, utilizing either proprietary or open-source libraries.

We furthermore determined that organizational, post-quantum cryptographic, as well as code- and document-based challenges are fundamental in RQ3 and explained their nature and origins. Thus, we help understanding and identifying those risk factors while planning or conducting an actual PQC migration which allows for proper mitigation.

As described in depth in Section IV, the current lack of maturity in PQC implementations, the lack of an established migration framework, and a missing concept for the concrete realization of a cryptographic inventory contribute to the sparse adaption of PQC in software systems. These obstacles must be counteracted as quickly as possible to ensure secure PQC solutions that can be implemented broadly.

REFERENCES

[1] C. Ma, L. Colon, J. Dera, B. Rashidi, and V. Garg, ''CARAF: Crypto agility risk assessment framework,'' *J. Cybersecurity*, vol. 7, no. 1, Feb. 2021, Art. no. tyab013.

[2] *CYBER; Migration Strategies and Recommendations to Quantum Safe Schemes*, document TR 103 619, ETSI, Jul. 2020.

[3] C. Adams, M. Ounsworth, S. Mister, F. Willems, J. Gray, J. Zahed, and J. Fan, ''Impact of post-quantum hybrid certificates on PKI, common libraries, and protocols,'' *Int. J. Secur. Netw.*, vol. 16, no. 3, pp. 200–211, 2021. [Online]. Available: https://www.inderscienceonline.com/doi/abs/10.1504/IJSN.2021.117887

[4] D. Weller and R. van der Gaag. (2020). *Incorporating Post-Quantum Cryptography in a Microservice Environment*. Accessed: Feb. 14, 2024. [Online]. Available: https://rp.os3.nl/2019-2020/p13/report.pdf

[5] A. Tueno, D. Boehm, and S. H. Choe, ''Integrating and evaluating quantum-safe TLS in database applications,'' in *Data and Applications Security and Privacy XXXVI*, S. Sural and H. Lu, Eds. Cham, Switzerland: Springer, 2022, pp. 259–278.

[6] E. Stamm, N. Smyth, and E. O'Sullivan. (2020). *Identity-Based Encryption: A Comparison of Leading Classical and Post-Quantum Implementations in an Enterprise Setting*. Accessed: Feb. 14, 2024. [Online]. Available: https://www.researchgate.net/profile/Emily-Stamm-2/publication/359684875_Identity-Based_Encryption_A_Comparison_of_Leading_Classical_and_Post-Quantum_Implementations_in_an_Enterprise_Setting/links/6247d90421077329f2e9dce7/Identity-Based-Encryption-A-Comparison-of-Leading-Classical-and-Post-Quantum-Implementations-in-an-Enterprise-Setting.pdf

[7] L. Zhang, A. Miranskyy, W. Rjaibi, G. Stager, M. Gray, and J. Peck, ''Making existing software quantum safe: A case study on IBM Db2,'' *Inf. Softw. Technol.*, vol. 161, Sep. 2023, Art. no. 107249. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S0950584923001039

[8] K. F. Hasan, L. Simpson, M. A. R. Baee, C. Islam, Z. Rahman, W. Armstrong, P. Gauravaram, and M. McKague. (2023). *Migrating to Post-Quantum Cryptography: A Framework Using Security Dependency Analysis*. Accessed: Feb. 14, 2024. [Online]. Available: https://arxiv.org/abs/2307.06520

[9] W. Barker and S. Murugiah. (2021). *Migration to Post-Quantum Cryptography*. Accessed: Feb. 14, 2024. [Online]. Available: https://www.nccoe.nist.gov/sites/default/files/legacy-files/pqc-migration-project-description-draft.pdf?trk=public_post_comment-text

[10] F. Müller and M. van Heesch. (2020). *Migration to Quantum-Safe Cryptography—About Making Decisions on When What and How to Migrate to a Quantum-Safe Situation*. Accessed: Feb. 14, 2024. [Online]. Available: https://repository.tno.nl/islandora/object/uuid%3A49ee6aa3-3eca-4c84-8908-02abd49674c1

[11] I. Mohammad and H. Burghoff, ''Migrating Nginx web servers to quantum-safe TLS,'' Ph.D. dissertation, Dept. IT, Univ. Copenhagen, Copenhagen, Denmark, 2021.

[12] S. Suhail, R. Hussain, A. Khan, and C. S. Hong, ''On the role of hash-based signatures in quantum-safe Internet of Things: Current solutions and future directions,'' *IEEE Internet Things J.*, vol. 8, no. 1, pp. 1–17, Jan. 2021.

[13] N. von Nethen, A. Wiesmaier, N. Alnahawi, and J. Henrich, ''PMMP—PQC migration management process,'' 2023, *arXiv:2301.04491*.

[14] R. Varma, C. Melville, C. Pinello, and T. Sahai, ''Post quantum secure command and control of mobile agents inserting quantum-resistant encryption schemes in the secure robot operating system,'' *Int. J. Semantic Comput.*, vol. 15, no. 3, pp. 359–379, Sep. 2021.

[15] A. Holcomb, G. Pereira, B. Das, and M. Mosca, ''PQFabric: A permissioned blockchain secure from both classical and quantum attacks,'' in *Proc. IEEE Int. Conf. Blockchain Cryptocurrency (ICBC)*, May 2021, pp. 1–9.

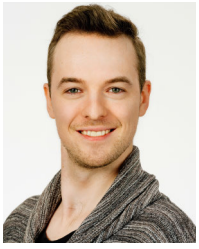
[16] C. Döberl, W. Eibner, S. Gärtner, M. Kos, F. Kutschera, and S. Ramacher, ''Quantum-resistant end-to-end secure messaging and email communication,'' in *Proc. 18th Int. Conf. Availability, Rel. Secur.* New York, NY, USA: Association for Computing Machinery, Aug. 2023, pp. 1–8.

[17] *Quantum-Safe Cryptography (QSC) Migration; ITS and C-ITS Migration Study*, document ETSI TR 103 949, ETSI Tech. Committee Cyber Secur. (CYBER), May 2023.

[18] M. Kiviharju, *Refining Mosca's Theorem: Risk Management Model for the Quantum Threat Applied to IoT Protocol Security*. Cham, Switzerland: Springer, 2022, pp. 369–401.
[19] A. Mashatan and D. Heintzman, "The complex path to quantum resistance: Is your organization prepared?" *Queue*, vol. 19, no. 2, pp. 65–92, May 2021.
[20] T. Attema, J. Duarte, V. Dunning, M. Lequesne, W. van der Schoot, and M. Stevens, "The PQC migration handbook guidelines for migrating to post-quantum cryptography," TNO-Appl. Cryptography Quantum Algorithms CWI, Cryptol. Group AIVD, Netherlands Nat. Commun. Secur. Agency, Hague, The Netherlands, Tech. Rep. 2, 2023. Accessed: Feb. 12, 2024. [Online]. Available: https://www.tno.nl/en/newsroom/2023/04-0/pqc-migration-handbook/
[21] B. White, D. Andre, G. Arquero, R. Bajaj, J. Cronin, A. Dames, H. Lyksborg, M. Alexandra, and M. Weiss, *Transitioning to Quantum-Safe Cryptography on IBM Z*. New York, NY, USA: IBM Redbook, 2022.
[22] F. Wilhelm, R. Steinwandt, D. Zeuch, and J. Frey, "Status of quantum computer development," Federal office for Inf. Secur., Bundesamt für Sicherheit in der Informationstechnik (BSI), Bonn, Germany, Tech. Rep. 2.0, 2023. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Studien/Quantencomputer/Entwicklungstand_QC_V_2_0.pdf
[23] S. Ehlen, H. Hagemeier, T. Hemmert, S. Kousidis, M. Lochter, S. Reinhardt, and T. Wunderer, "Kryptographie sicher gestalten," Bundesamt für Sicherheit der Informationstechnik (BSI), Bonn, Germany, Tech. Rep. BSI-Bro21/01, Oct. 2021.
[24] J. R. Biden Jr. (May 2022). *National Security Memorandum on Promoting United States Leadership in Quantum Computing While Mitigating Risks to Vulnerable Cryptographic Systems (NSM-10)*. White House. [Online]. Available: https://www.whitehouse.gov/briefing-room/statements-releases/2022/05/04/national-security-memorandum-on-promoting-united-states-leadership-in-quantum-computing-while-mitigating-risks-to-vulnerable-cryptographic-systems/
[25] Matt Braithwaite. (2016). *Experimenting With Post-Quantum Cryptography*. Accessed: Mar. 11, 2024. [Online]. Available: https://security.googleblog.com/2016/07/experimenting-with-post-quantum.html
[26] K. Kwiatkowski and L. Valenta. (2019). *The TLS Post-Quantum Experiment*. Accessed: Mar. 11, 2024. [Online]. Available: https://blog.cloudflare.com/the-tls-post-quantum-experiment
[27] A. Lohachab, A. Lohachab, and A. Jangra, "A comprehensive survey of prominent cryptographic aspects for securing communication in post-quantum IoT networks," *Internet Things*, vol. 9, Mar. 2020, Art. no. 100174.
[28] A. Wiesmaier, N. Alnahawi, T. Grasmeyer, J. Gei ler, A. Zeier, P. Bauspie, and A. Heinemann, "On PQC migration and crypto-agility," 2021, *arXiv:2106.09599*.
[29] N. Alnahawi, N. Schmitt, A. Wiesmaier, A. Heinemann, and T. Grasmeyer, "On the state of crypto-agility," Cryptol. ePrint Arch., Univ. Appl. Sci., Darmstadt, Germany, Paper 2023/487, 2023. [Online]. Available: https://eprint.iacr.org/2023/487
[30] A. A. Giron, R. Custódio, and F. Rodríguez-Henríquez, "Post-quantum hybrid key exchange: A systematic mapping study," *J. Cryptograph. Eng.*, vol. 13, no. 1, pp. 71–88, Apr. 2022.
[31] M. J. Page et al., "The PRISMA 2020 statement: An updated guideline for reporting systematic reviews," *Systematic Rev.*, vol. 10, no. 1, p. 89, Mar. 2021, doi: 10.1186/s13643-021-01626-4.
[32] B. Kitchenham and P. Brereton, "A systematic review of systematic review process research in software engineering," *Inf. Softw. Technol.*, vol. 55, no. 12, pp. 2049–2075, Dec. 2013. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S0950584913001560
[33] K. Petersen, S. Vakkalanka, and L. Kuzniarz, "Guidelines for conducting systematic mapping studies in software engineering: An update," *Inf. Softw. Technol.*, vol. 64, pp. 1–18, Aug. 2015. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S0950584915000646
[34] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Berlin, Heidelberg: Springer, 2012. [Online]. Available: http://link.springer.com/10.1007/978-3-642-29044-2
[35] P.-P. Group, D. Moher, L. Shamseer, M. Clarke, D. Ghersi, A. Liberati, M. Petticrew, P. Shekelle, and L. A. Stewart, "Preferred reporting items for systematic review and meta-analysis protocols (PRISMA-P) 2015 statement," *Systematic Rev.*, vol. 4, no. 1, p. 1, Jan. 2015, doi: 10.1186/2046-4053-4-1.
[36] D. Stebila, S. Fluhrer, and S. Gueron, "Hybrid key exchange in TLS 1.3," Internet Eng. Task Force, Reston, VA, USA, Tech. Rep. 9, Sep. 2023.
[37] P. Kampanakis, D. Stebila, M. Friedl, T. Hansen, and D. Sikeridis. (Oct. 2020). *Post-Quantum Public Key Algorithms for the Secure Shell (SSH) Protocol*. Internet Eng. Task Force. [Online]. Available: https://datatracker.ietf.org/doc/draft-kampanakis-curdle-pq-ssh-00
[38] D. Ott and C. Peikert, "Identifying research challenges in post quantum cryptography migration and cryptographic agility," 2019, *arXiv:1909.07353*.
[39] W. Barker, W. Polk, and M. Souppaya, "Getting ready for post-quantum cryptography: Exploring challenges associated with adopting and using post-quantum cryptographic algorithms," Nat. Inst. Standards Technol., Gaithersburg, MD, USA, Tech. Rep. CSWP 15, 2021, doi: 10.6028/NIST.CSWP.04282021.
[40] E. SAS. (2023). *PQC Migration Guide—The Essentials*. [Online]. Available: https://www.cryptovision.com/wp-content/uploads/2023/05/EVIDEN-PQC-Migration-Guide.pdf
[41] N. Alnahawi, A. Wiesmaier, T. Grasmeyer, J. Geißler, A. Zeier, P. Bauspieß, and A. Heinemann, "On the state of post-quantum cryptography migration," in *Proc. Lect. Notes Informat.*, 2021, pp. 1–35. [Online]. Available: https://dl.gi.de/server/api/core/bitstreams/dba4839d-5652-4740-8fec-7b3893ee614a/content
[42] Federal Office Inf. Secur. (2021). *Migration to Post Quantum Cryptography—Recommendations for Action by the BSI*. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Crypto/Migration_to_Post_Quantum_Cryptography.pdf?__blob=publicationFile&v=2
[43] Nat. Inst. Standards Technol. (2023). *Quantum-Readiness: Migration to Post-Quantum Cryptography*. [Online]. Available: https://www.cisa.gov/sites/default/files/2023-08/Quantum%20Readiness_Final_CLEAR_508c%20%283%29.pdf
[44] Cryptosense SA. (2020). *Cryptography Inventory—Building, Maintaining and Exploiting a Useful Inventory*. Accessed: Mar. 14, 2024. [Online]. Available: https://query.prod.cms.rt.microsoft.com/cms/api/am/binary/RWP0kj
[45] FS-ISAC. (2023). *Infrastructure Inventory Technical Paper*. Accessed: Mar. 14, 2024. [Online]. Available: https://www.fsisac.com/hubfs/Knowledge/PQC/InfrastructureInventory.pdfhttps
[46] J. R. Biden Jr., (2021). *Executive Order on Improving the Nation's Cybersecurity*. White House. [Online]. Available: https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/
[47] A. Huelsing, D. Butin, S.-L. Gazdag, J. Rijneveld, and A. Mohaisen, *XMSS: EXtended Merkle Signature Scheme*, document RFC 8391, May 2018. [Online]. Available: https://www.rfc-editor.org/info/rfc8391
[48] D. McGrew, M. Curcio, and S. Fluhrer, *Leighton-Micali Hash-Based Signatures*, document RFC 8554, Apr. 2019. [Online]. Available: https://www.rfc-editor.org/info/rfc8554
[49] V. Smyslov, *Intermediate Exchange in the Internet Key Exchange Protocol Version 2 (IKEv2)*, document RFC 9242, May 2022. [Online]. Available: https://www.rfc-editor.org/info/rfc9242
[50] C. Tjhai, M. Tomlinson, G. Bartlett, S. Fluhrer, D. V. Geest, O. Garcia-Morchon, and V. Smyslov, *Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2)*, document RFC 9370, May 2023. [Online]. Available: https://www.rfc-editor.org/info/rfc9370
[51] D. Herzinger, S.-L. Gazdag, and D. Loebenberger, "Real-world quantum-resistant IPsec," in *Proc. 14th Int. Conf. Secur. Inf. Netw. (SIN)*, vol. 1, Dec. 2021, pp. 1–8.
[52] Federal Office Inf. Secur. (2024). *BSI TR-02102-1 Kryptographische Verfahren: Empfehlungen Und Schl Gn*. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.pdf?__blob=publicationFile&v=10
[53] P. Julien, M. Ounsworth, and D. V. Geest. (2024). *Use of ML-KEM in the Cryptographic Message Syntax (CMS)*. [Online]. Available: https://datatracker.ietf.org/doc/draft-ietf-lamps-cms-kyber/03/
[54] P. Schwabe and B. Westerbaan. (Jan. 2024). *Kyber Post-Quantum KEM*. Internet Eng. Task Force. [Online]. Available: https://datatracker.ietf.org/doc/draft-cfrg-schwabe-kyber/04/
[55] S. Turner, P. Kampanakis, J. Massimo, and B. Westerbaan. (Mar. 2024). *Internet X.509 Public Key Infrastructure—Algorithm Identifiers for Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM)*. [Online]. Available: https://datatracker.ietf.org/doc/draft-ietf-lamps-kyber-certificates/03/
[56] B. Westerbaan and D. Stebila. (Sep. 2023). *X25519Kyber768Draft00 Hybrid Post-quantum Key Agreement*. Internet Eng. Task Force. [Online]. Available: https://datatracker.ietf.org/doc/draft-tls-westerbaan-xyber768d00/03/
[57] A. Ampatzoglou, S. Bibi, P. Avgeriou, and A. Chatzigeorgiou, "Guidelines for managing threats to validity of secondary studies in software engineering," in *Contemporary Empirical Methods in Software Engineering*. Cham, Switzerland: Springer, 2020, pp. 415–441.



CHRISTIAN NÄTHER received the master's degree in computer science from the University of Augsburg, Germany. As a former software engineer, he has gained several years of experience in the fields of software development, distributed systems, and information security. He is currently a Security Researcher at XITASO and part of the research project AMiQuaSy, which focuses on the migration of systems toward post-quantum cryptography. He is an active board member of XITASO's information security community, where he promotes both internal and customer-specific security.



DANIEL HERZINGER received the M.Sc. degree in computer science. He started working on post-quantum cryptography (PQC) and its adoption into real-world scenarios during his master's thesis, in 2020, together with genua–German IT security company, where he started his IT security journey, in 2015. After finishing his studies, he first dived into supporting customers with securing their IT and OT infrastructures at genua's consulting department for two years. Then, he indulged in his passion for PQC by joining the research group focusing on the transition of complex systems and infrastructures to quantum resistance, in 2023.



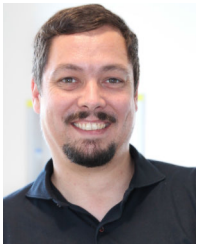
STEFAN-LUKAS GAZDAG received the M.Sc. degree in computer science. Since 2013, he has focused on post-quantum cryptography (PQC) and future-proof security mechanisms overcoming obstacles in practical use. Being part of German IT security company genua's research group he currently works on the third publicly funded PQC research project and other collaborations, enabling the transition to quantum-safe networks. He was e.g. involved in the publication of the first explicit PQC RFC, RFC 8391 describing the signature scheme XMSS, recommended e.g. by U.S. NIST, NSA, and German BSI.



JAN-PHILIPP STEGHÖFER (Member, IEEE) received the Ph.D. degree in computer science from the University of Augsburg, Germany. As a former Professor at the University of Gothenburg he has an extensive and distinguished academic background with a strong passion for research and innovation. He is currently a Senior Researcher at XITASO as well as an active member of the software engineering community, where he is part of the organization committee for events, such as the IEEE International Requirements Engineering Conference (RE). His research interests include security assurance, security of AI systems, agile development in regulated domains, and model-driven engineering. He reviews for the International Conference on Software Engineering (ICSE), IEEE TRANSACTIONS ON SOFTWARE ENGINEERING, *Journal of Systems and Software*, and *Empirical Software Engineering and Measurement*.



SIMON DAUM received the Ph.D. degree from the Chair of Computational Modeling and Simulation, Technical University of Munich, in 2018. Then, he continued his research in this field, until 2021. Since then, he has been the Head of Research at genua GmbH and is responsible for the strategic selection and successful implementation of a wide range of research topics in the field of IT security.



DANIEL LOEBENBERGER received the Ph.D. degree in cryptography from the University of Bonn, in 2012. He conducted research and taught at the University of Bonn, until the end of 2015. From 2016 to 2019, he was an IT Security Expert with a focus on cryptography at genua GmbH, a subsidiary of the Bundesdruckerei GmbH, German Federal Printing Office, on various topics of professional high-security components. Since January 2019, he has been appointed as a Professor of cybersecurity at the Technical University Amberg-Weiden and the Head of the Secure Infrastructure Department, Fraunhofer AISEC, Weiden site. In the laboratory there, topics of applied post-quantum cryptography and quantum-safe infrastructures are addressed in research and teaching.